Trazabilidad y respuesta a incidentes

Actividad 7 NortiShop

Asignatura: Seguridad y Protección de Datos

Caso: Plataforma de comercio electrónico NortiShop

Integrantes: Ariel Van Kilsdonk y Carlos Orellana

Fecha: 11 de noviembre de 2026

1 Introducción

El sistema ya distingue clientes, personal de soporte, marketing, logística, finanzas, administración, DPO, auditor y oficial de seguridad. Sobre esos permisos registramos los accesos y operaciones que podrían comprometer datos personales. El registro permite investigar quién hizo qué, sobre qué recurso y con qué resultado, sin conservar en la bitácora el contenido consultado o modificado.

2 Eventos y campos de auditoría

Grupo	Eventos auditados
Identidad y permisos	Inicio y cierre de sesión, bloqueo, registro, acceso API autorizado o denegado y cambio de rol.
Datos y derechos	Lectura sensible o enmascarada, modificación, exportación, supresión, oposición, solicitud, verificación, evaluación, ejecución, rechazo, cierre y prórroga.
Tratamientos	Consentimiento otorgado o revocado, pedido, despacho, reversión de seudónimo, reporte anonimizado.
Seguridad	Consulta y verificación de auditoría, alerta, apertura y fases del incidente, preservación de evidencia, rotación de llaves, errores internos.

Cada fila audit_log contiene event_id, occurred_at UTC, actor_type, actor_ref opaco, actor_role, action, resource_type, resource_ref, result, request_id, prefijo de IP, details saneado, prev_hash y hash. No guarda nombres, RUT, correos, teléfonos, contraseñas, tokens ni cuerpos de tickets. Las claves sensibles se omiten y los patrones de datos personales se enmascaran antes de insertar. La IP se reduce a /24 en IPv4 o /48 en IPv6.

3 Protección y conservación

El registro se inserta desde la conexión interna del sistema. Las conexiones de roles de negocio no pueden escribir audit_log y solo auditor, DPO y oficial de seguridad pueden consultarlo mediante la API. Cada evento lleva un HMAC encadenado al anterior. Un trigger impide UPDATE y otro impide borrar filas dentro del plazo de 730 días. La purga de registros vencidos deja un ancla para verificar la cadena restante. La consulta del registro también se audita. En producción se requiere una base separada o un almacén externo de solo adición, controles de sistema operativo y respaldo cifrado; SQLite por sí solo no resiste a un administrador con acceso al archivo.

4 Alertas de NortiShop

Regla	Disparo	Acción inicial
Fuerza bruta	5 inicios de sesión denegados para un actor en 10 minutos.	Revisar cuenta y origen; bloquear sesión si corresponde.
Acceso denegado reiterado	5 operaciones denegadas para un actor en 10 minutos.	Revisar permisos y posible abuso interno.
Exportación anómala	3 exportaciones exitosas en 24 horas.	Validar titular y suspender descargas si hay riesgo.
Lectura masiva	50 lecturas enmascaradas de clientes en 10 minutos.	Revisar consulta de personal y alcance afectado.

La ruptura de integridad de la cadena se considera crítica y abre un incidente automáticamente. Las demás reglas generan una alerta para análisis del oficial de seguridad; una alerta por sí sola no prueba una filtración.

5 Plan de respuesta

Fase	Responsable y decisión
Detección y análisis	Oficial de seguridad valida registros, alerta, alcance, categorías y severidad. DPO evalúa riesgo para titulares.
Contención	Operaciones revoca sesiones o credenciales comprometidas, congela exportaciones y limita accesos. Primero preserva la evidencia.
Erradicación	Equipo técnico corrige la causa, rota llaves si hubo exposición y verifica que no queden accesos indebidos.
Recuperación	Operaciones restaura servicio, comprueba integridad y reaplica supresiones al recuperar respaldos.
Notificación y cierre	DPO decide la comunicación con apoyo legal; dirección aprueba el envío. Se registran acciones, resultado y mejoras.

Se abre un incidente ante acceso no autorizado confirmado, pérdida o alteración de datos, exposición de credenciales o falla de integridad de auditoría. Desde el 1 de diciembre de 2026, si existe riesgo razonable para derechos y libertades, el art. 14 sexies de la Ley 21.719 exige reportar a la Agencia sin dilaciones indebidas. Si afecta datos sensibles, de menores de 14 años o relativos a obligaciones económicas, financieras, bancarias o comerciales, también se comunica a cada titular. Antes de esa fecha, se documenta la evaluación y se aplican las obligaciones vigentes y contractuales que correspondan.

La notificación preparada para un caso real debe indicar naturaleza y momento estimado del hecho, categorías de datos, número aproximado de titulares, consecuencias posibles, medidas de contención y resguardo adoptadas, medidas recomendadas para el titular y un canal de contacto. La versión a la Agencia incluye el fundamento de riesgo y las actualizaciones posteriores. La comunicación al titular usa lenguaje claro y evita revelar datos de otras personas.

6 Simulación y reconstrucción

Simulamos cinco intentos denegados del empleado sintético EMP-1 contra la consulta de clientes dentro de diez minutos. El detector abrió la alerta accesos_denegados_reiterados. El oficial de seguridad abrió un incidente de severidad alta y preservó una copia de los eventos y alertas con SHA-256. Al consultar la bitácora se recuperaron los cinco eventos, su actor, acción, resultado y secuencia temporal; la verificación HMAC de la cadena resultó válida. El caso representa un intento bloqueado, por lo que no demuestra una filtración ni activa por sí mismo una notificación externa.

La prueba se encuentra en scripts/probar_actividades_6_7.py y se ejecutó junto con las demás pruebas directas el 11 de noviembre de 2026. También terminaron correctamente las 51 pruebas HTTP, incluidas las consultas API, la consulta de auditoría sin valores de filtros y el flujo completo de incidentes. El archivo de evidencia preservado se crea en una carpeta temporal durante la prueba y se elimina al terminar; no contiene datos personales reales.

7 Conclusión

La auditoría conserva contexto suficiente para reconstruir operaciones sin duplicar el contenido personal. Los permisos, el encadenamiento HMAC y la retención de dos años protegen la evidencia dentro del alcance académico. La simulación verificó el paso desde evento a alerta, incidente y copia de evidencia. Para producción se requiere centralizar registros fuera de SQLite, monitorear el envío de alertas y ensayar la notificación con responsables reales.

8 Referencias

Biblioteca del Congreso Nacional de Chile. Ley 21.719, arts. 14 quinquies y 14 sexies, vigencia desde 01-12-2026. https://www.bcn.cl/leychile/navegar?idNorma=1209272

Repositorio NortiShop. Actividad 3, Informe Hito 1; Sistema_NortiShop/nortishop/audit.py, security.py y schema.sql; scripts/probar_actividades_6_7.py.